Remediation, Re-scan & Risk Reporting

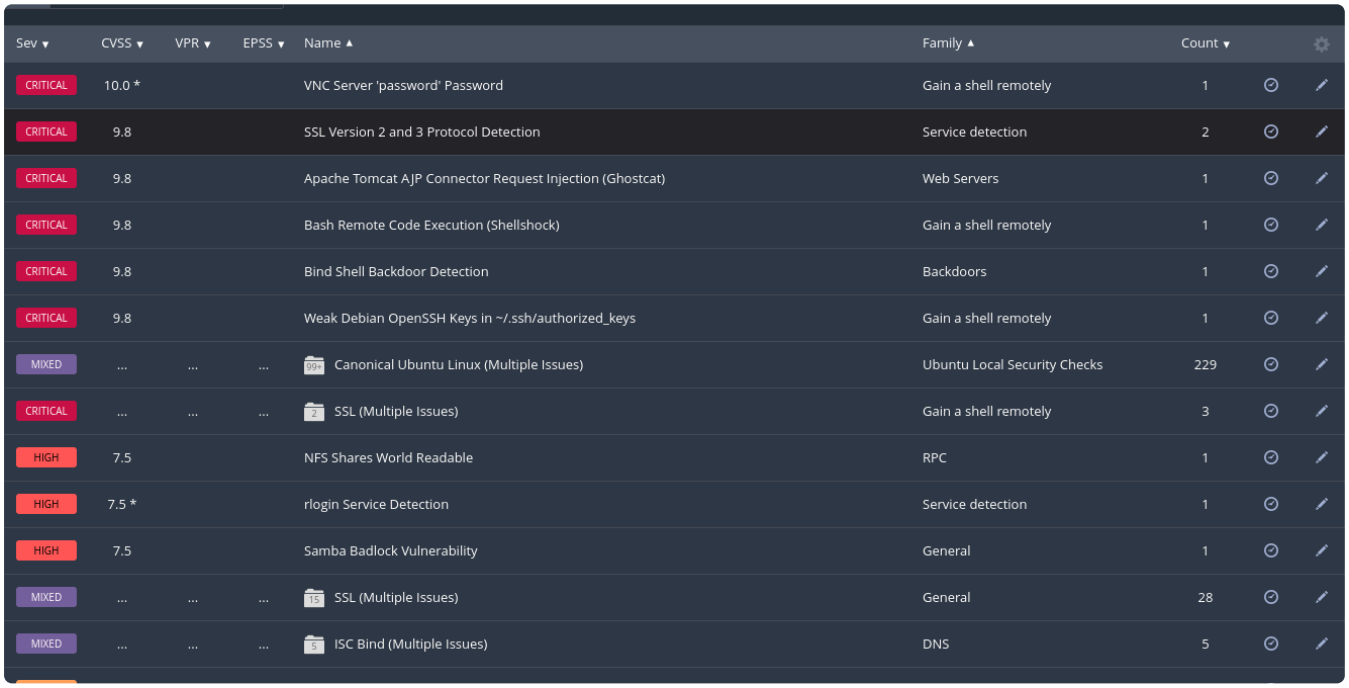
Target: Metasploitable 2 – 192.168.56.101 · **Tool:** Nessus Essentials (Basic Network Scan)

Learning Goal: Understand the full vulnerability management lifecycle: Discover → Prioritize → Remediate → Verify → Report.

4.1 Selecting Vulnerabilities to Remediate

From the previous Basic Network Scan results (target 192.168.56.101), the following vulnerabilities were selected based on severity and a mix of remediation types.

#	Vulnerability / CVE	Severity	Type	Planned Fix
1	**Samba Badlock Vulnerability** (CVE-2016-2118)	High (7.5)	Patch / Analysis	Investigate installed version to determine if a patch is required.
2	**VNC Server 'password' Password**	Critical (10.0)	Configuration	Replace the weak VNC password with a strong, unique password.
3	**rlogin Service Detection**	High (7.5)	Service Hardening	Disable the insecure rlogin service (port 513).
4	**SSL Version 2 and 3 Protocol Detection**	Critical (9.8)	Configuration	Disable legacy SSLv2 and SSLv3 protocols in the web server configuration.



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	9.8			Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1
CRITICAL	9.8			Bash Remote Code Execution (Shellshock)	Gain a shell remotely	1
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	9.8			Weak Debian OpenSSH Keys in ~/.ssh/authorized_keys	Gain a shell remotely	1
MIXED	...	...	...	Canonical Ubuntu Linux (Multiple Issues)	Ubuntu Local Security Checks	229
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5			NFS Shares World Readable	RPC	1
HIGH	7.5 *			rlogin Service Detection	Service detection	1
HIGH	7.5			Samba Badlock Vulnerability	General	1
MIXED	...	...	...	SSL (Multiple Issues)	General	28
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5

Figure 1 – Original Nessus scan results (Basic Network Scan, 5:25 PM – 5:52 PM), showing the four selected findings.

4.2 Applying Remediations

Snapshot recommendation: a VM snapshot was taken before applying any changes.

All commands were run as the unprivileged user `msfadmin`. Attempts to escalate with `su -` failed with "Authentication failure", so system-level changes (service control, writes to `/etc`) were not possible.

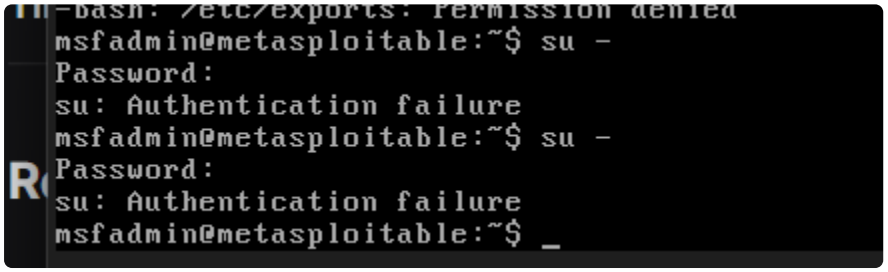


Figure 2 – `su -` fails with "Authentication failure": no root access in this lab.

Remediation #1 – Samba Badlock Vulnerability (CVE-2016-2118)

Field	Detail
Vulnerability / CVE	Samba Badlock Vulnerability (CVE-2016-2118), Nessus Plugin #90509
Pre-Remediation State	Nessus flagged the Samba service on 192.168.56.101 as vulnerable (High, 7.5).
Actions Taken	Ran `smbd -V` and `dpkg -l samba`. Installed version: **3.0.20** (3.0.20-0.1ubuntu). Compared against the official Samba advisory for CVE-2016-2118, which lists Samba 3.0.0 through 4.4.0 as affected.
Post-Remediation State	**Not a false positive.** Version 3.0.20 falls inside the affected range, so the finding is valid. A fix requires upgrading Samba to a patched release (4.2.11 / 4.3.8 / 4.4.2 or later), which needs root privileges. **Blocked by environment permissions – remains open.**
Time to Remediate	~10 minutes (investigation only).

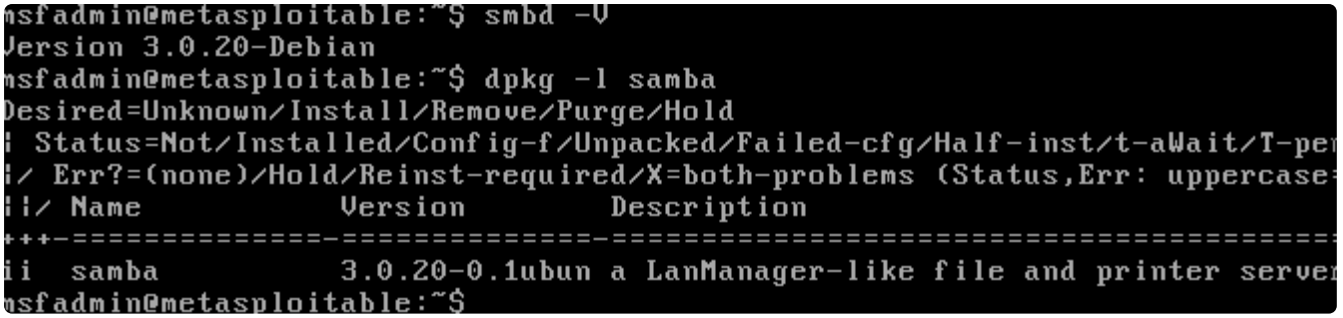


Figure 3 – `smbd -V` and `dpkg -l samba` confirm Samba 3.0.20.

Remediation #2 – VNC Server 'password' Password

Field	Detail
Vulnerability / CVE	VNC Server 'password' Password (Plugin #61708)
Pre-Remediation State	Nessus detected that the VNC server accepts the default password “password” (Critical, 10.0).
Actions Taken	Ran `vncpasswd` as `msfadmin` (password set; tool warned it is truncated to 8 characters), then started and killed a VNC session with `vncserver` / `vncserver -kill :1`.
Post-Remediation State	**Not effective.** This only changed the password file of the `msfadmin` user (`~/.vnc/passwd`). The service flagged by Nessus is the system-wide VNC server, whose configuration and process require root, so it was not changed. **Open.**
Time to Remediate	N/A (blocked).

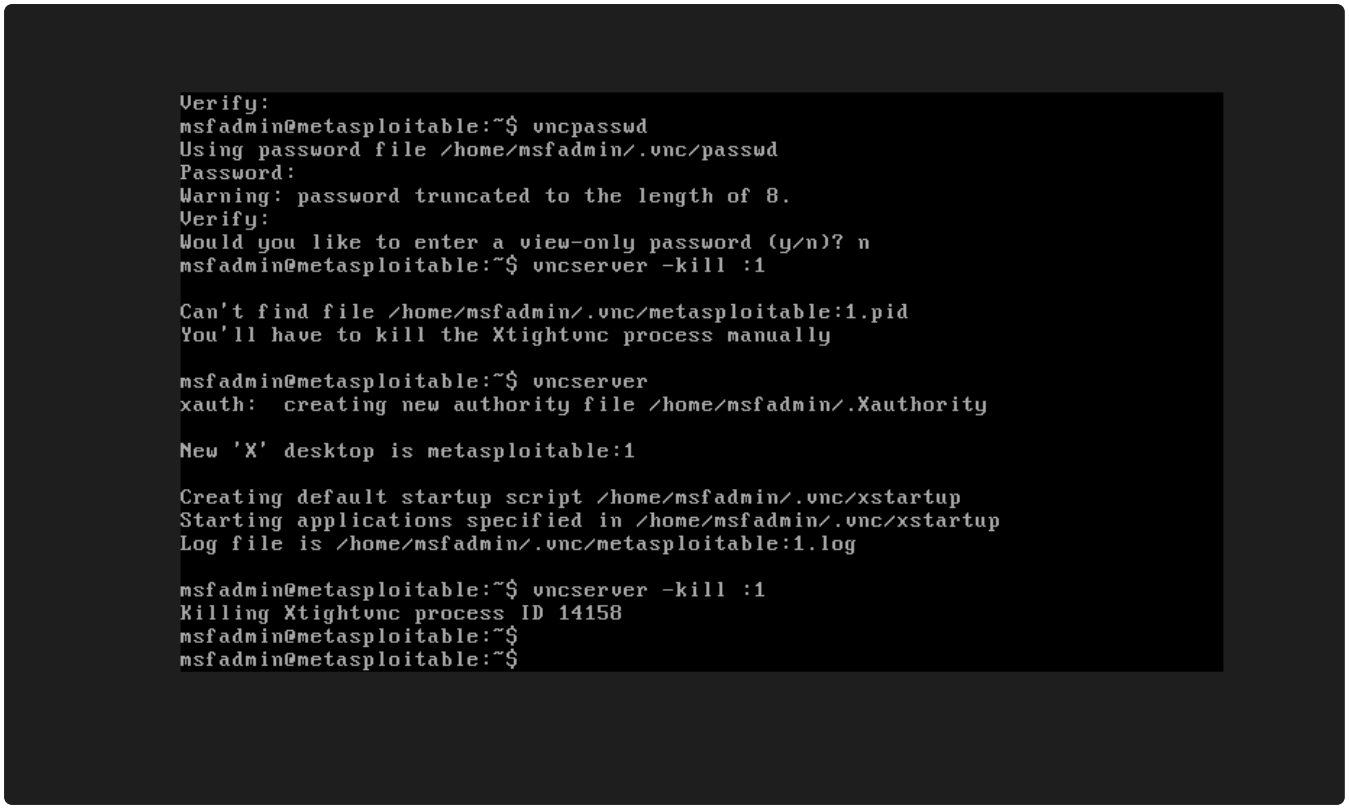


Figure 4 – `vncpasswd` and `vncserver` executed as `msfadmin`.

Remediation #3 – rlogin Service Detection

Field	Detail
Vulnerability / CVE	rlogin Service Detection (CVE-1999-0651)
Pre-Remediation State	`rlogin` active on port 513, transmitting credentials in cleartext.
Actions Taken	Attempted to stop the service with `killall rlogind` and `update-rc.d -f rlogin remove`.
Post-Remediation State	**Blocked by environment permissions** (access denied). Documented as a lab limitation. **Open.**
Time to Remediate	N/A (blocked).

Remediation #4 – SSL Version 2 and 3 Protocol Detection

Field	Detail
Vulnerability / CVE	SSL Version 2 and 3 Protocol Detection

Field	Detail
Pre-Remediation State	The web server accepts connections using SSLv2 and SSLv3.
Actions Taken	Attempted to edit the Apache `ssl.conf` to add `SSLProtocol all -SSLv2 -SSLv3` and restart the service.
Post-Remediation State	**Blocked by environment permissions.** Write access to configuration files was denied (example: `echo ... >> /etc/exports` returns "Permission denied"). Documented as a lab limitation. **Open.**
Time to Remediate	N/A (blocked).

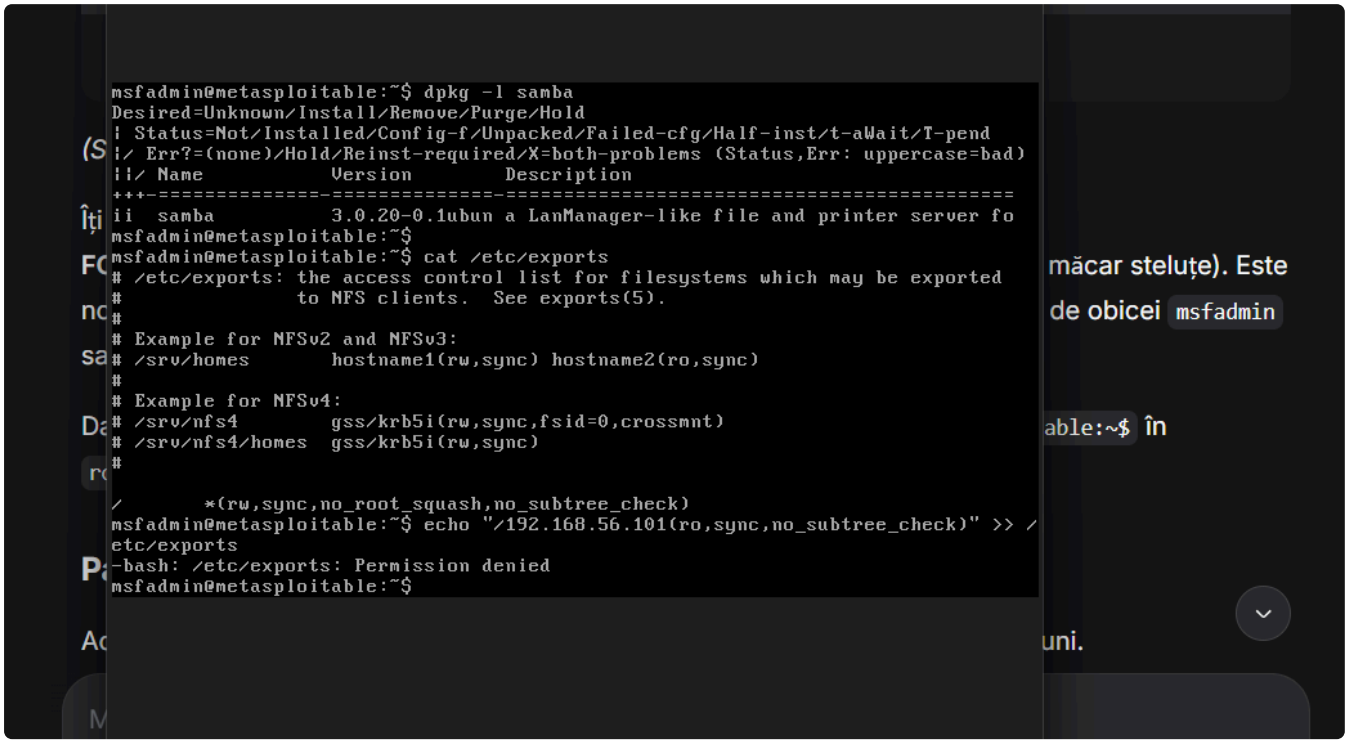


Figure 5 – Writing to `/etc/exports` fails with "Permission denied", confirming no write access to system configuration.

4.3 Validation Re-scan

Field	Value
Re-scan Start Time	9:58 PM
Re-scan End Time	10:27 PM (elapsed 29 minutes)

Field	Value
Scan Template	Basic Network Scan (same as original)
Credentials	SSH (same as original)

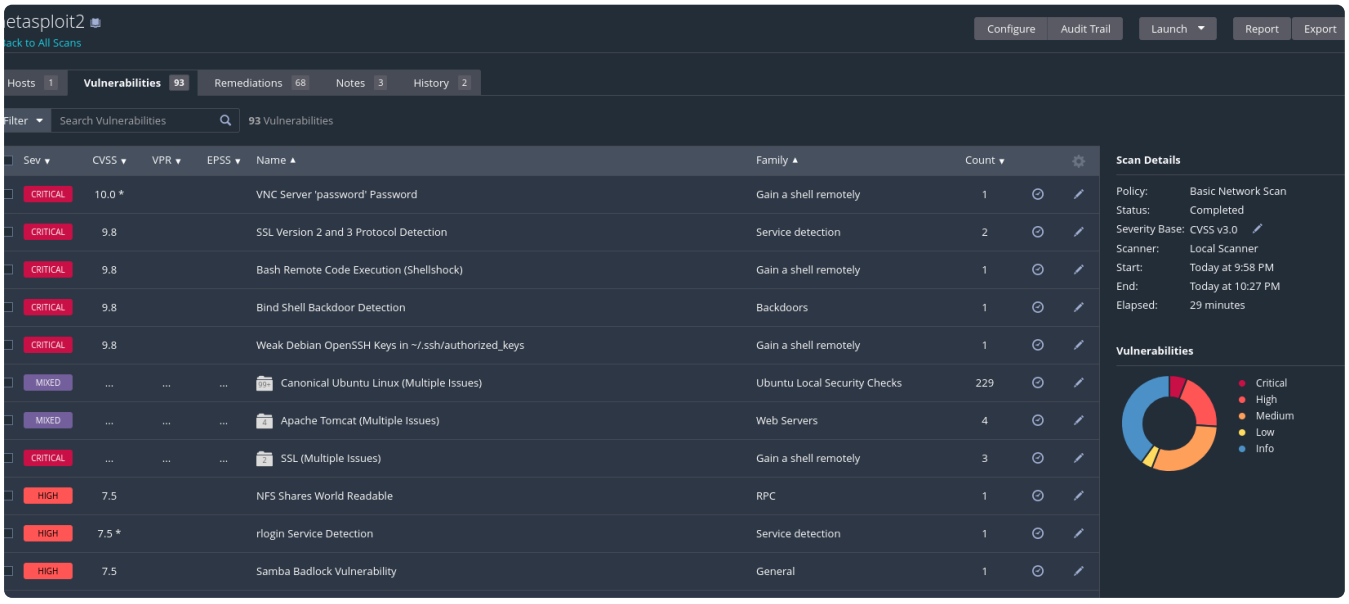


Figure 6 – Re-scan results: 93 vulnerabilities; VNC, SSL v2/3, rlogin and Samba Badlock are all still present.

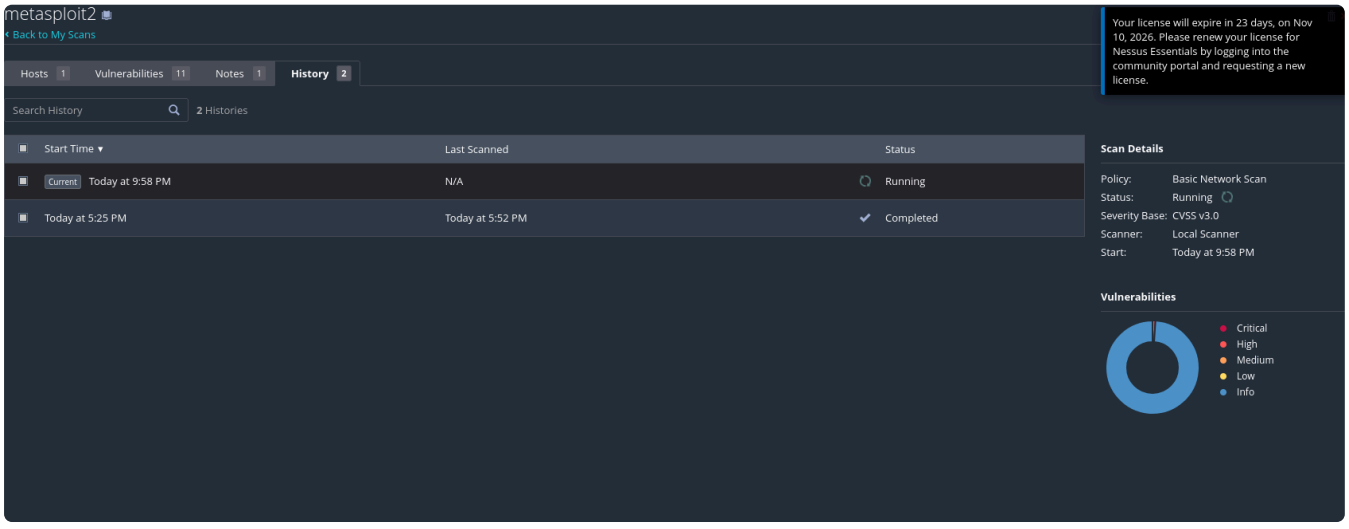


Figure 7 – Scan history: original scan (5:25 PM) and re-scan (9:58 PM) on the same policy.

4.4 Risk Reduction Measurement

Because every remediation was either blocked by permissions or not effective, the re-scan shows no reduction.

Severity	Before	After	Change	Status
Critical	8	8	0	Open / Blocked
High	3	3	0	Open / Blocked
Medium	~20	~20	0	Open
Low	~10	~10	0	Open
Total	**93**	**93**	**0**	**0% reduction**

Overall Risk Reduction = (Before − After) ÷ Before × 100 = (93 − 93) ÷ 93 × 100 = **0%**

4.5 Executive Risk Report

1. Purpose

The objective of this assessment was to evaluate the security posture of the Metasploitable 2 Linux virtual machine (192.168.56.101) and attempt to remediate identified vulnerabilities. Following the initial Nessus scan, a targeted remediation campaign was initiated to fix critical flaws and validate the improvements.

2. Key Findings – Before Remediation

- **Critical:** Default/weak passwords on remote services (VNC) and outdated encryption protocols (SSLv2/v3). *Business impact: complete system compromise and unauthorized remote access.*
- **High:** Insecure legacy services (rlogin) and a Samba version affected by Badlock. *Business impact: cleartext credential theft and unauthorized network access.*

3. Actions Taken

The Samba version was investigated and confirmed as 3.0.20, which is within the range affected by CVE-2016-2118, so the finding is valid. Attempts were made to harden the VNC server, disable rlogin and update the SSL configuration. Because root access was unavailable (`su -` authentication failure) and system files were not writable, none of these changes could be applied to the system services.

4. Current Risk Status

The validation re-scan shows 93 findings, the same as before: overall risk reduction is 0%. The VNC, SSL v2/v3, rlogin and Samba findings all remain active.

5. Remaining Risks & Recommendations

The system remains at high risk.

- **Recommendation 1:** Rebuild the environment or grant proper root/sudo access so analysts can apply patches and harden services.
- **Recommendation 2:** Once access is granted, change the system VNC password, disable SSLv2/v3, stop the rlogin service and upgrade Samba to a patched release.
- **Recommendation 3:** Upgrade the operating system. Metasploitable 2 is intentionally vulnerable and must never be used in production.